

Too **B**ig to Review

Scaling AppSec to Zero
at Fortune #1



Adam Schaal • @clevernyyyy

September 12th, 2026



Pixee



About Me

Adam Schaal

Distinguished Engineer at Pixee AI



Former Head of AWS SHINE



Co-founder of Kernelcon



LocoMocoSec Organizing Committee



Blue Team Con CTF Blue Badge Holder



@clevernyyyy



/in/adamschaal





My Time at AWS



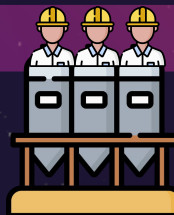
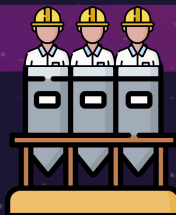
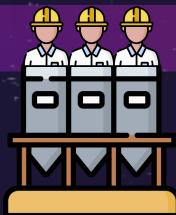
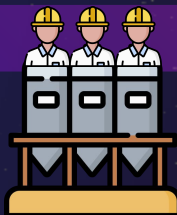
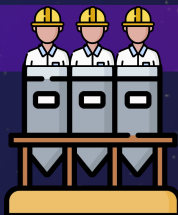
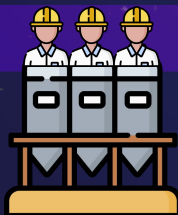
AppSec Director



Senior Managers



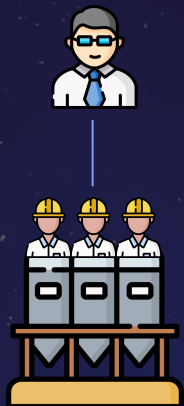
AppSec Managers



AppSec Engineers



My Time at AWS



"Platform"



All Infrastructure-as-Code, including Cloud Development Kit (CDK) and CloudFormation



AWS Console – Main entry point for users



AWS Mobile, Device Farm, AppSync



AWS-produced Open Sourced Software



Simple Email Service (SES), AWS Pinpoint



Amazon NGDE (Next-Gen Developer Experience)



My Time at AWS



Amazon NGDE (Next-Gen Developer Experience)



Plan to unveil NDGE at re:Invent 2023
AI-Powered Developer Tools



Dogfooding resulted in Productivity
**More output from Builders → More
security reviews for AppSec**



Security was now the blocker
We couldn't review code fast enough!



Examining Challenges at Scale



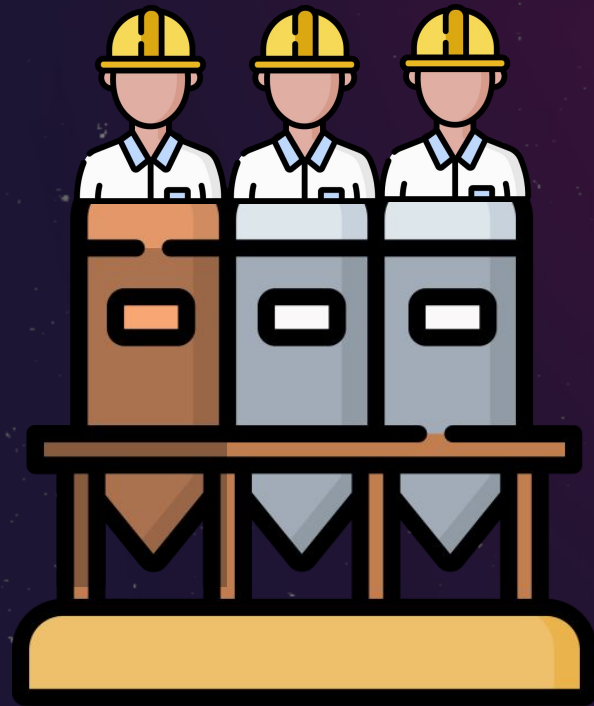
Single Bottleneck for Engineering
14k Security Reviews per Year!



Prioritization is Not Transparent
How do Builders timebox their Reviews?



Career Growth
Engineers grow by expanding breadth,
not depth!



Traditional AppSec Will NOT Scale in GenAI Era

AI-aided development has changed AppSec forever.



How Do We Address these Challenges

Removing Security Friction

Security is often viewed as major friction, like pushing a block uphill.



We need to reframe the problem rather than iterating on the same approach.



What if you could make that block easier to push?

Secure-by-Default Golden Paths



What if you could change the pitch of the hill?

Automated Security checks in the CI/CD.





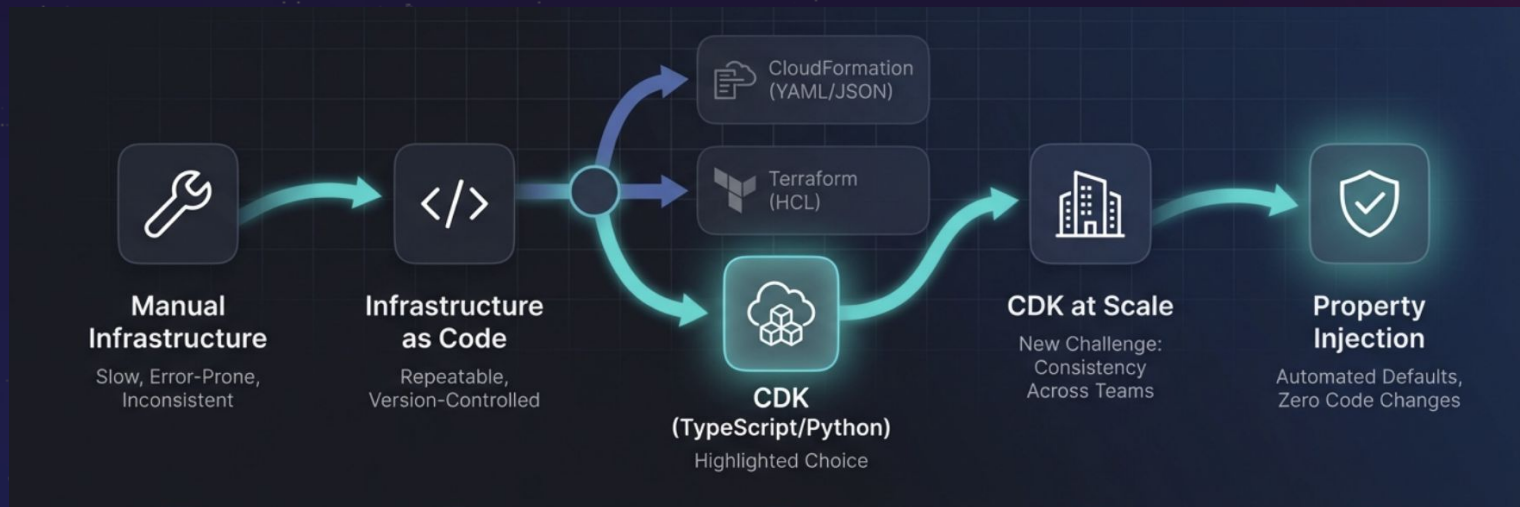
Secure-by-Default Golden Paths

2 types of environments





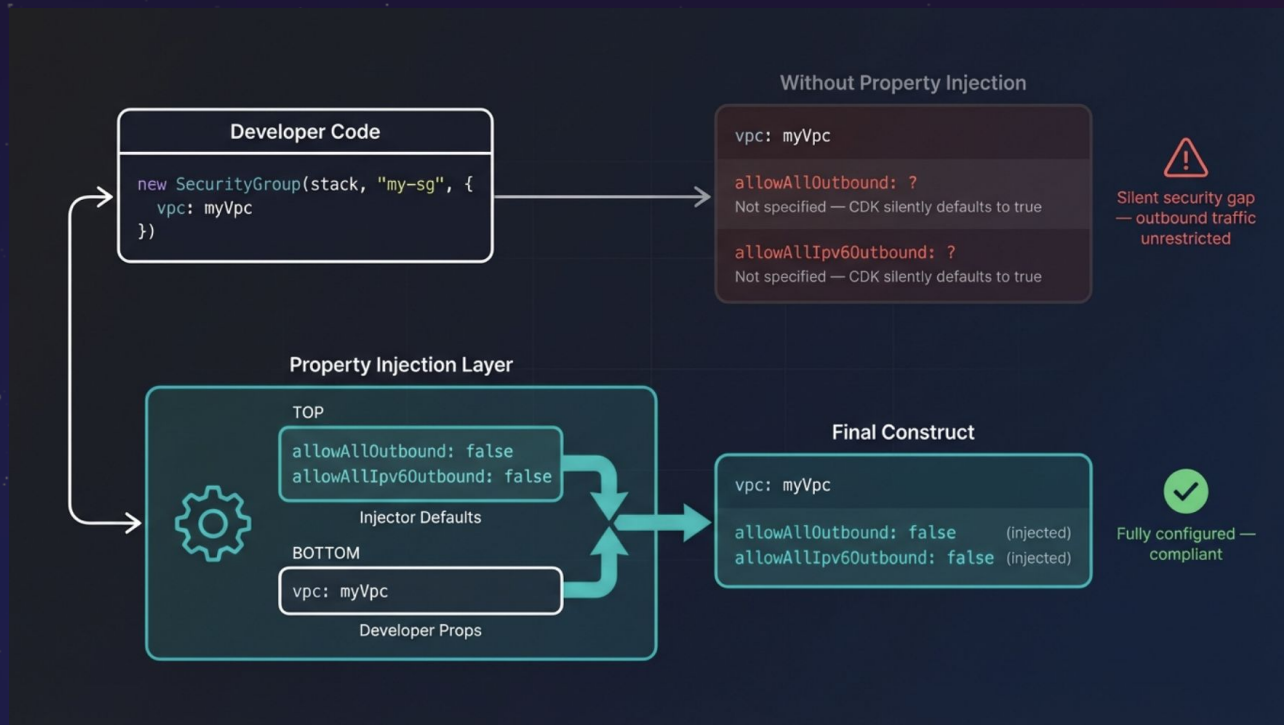
Secure-by-Default Golden Paths



93% of new applications
are built using AWS CDK



CDK Property Injection



<https://github.com/aws/aws-cdk/blob/main/packages/aws-cdk-lib/README.md#blueprint-property-injection>



CDK Property Injection

```
export class InfraStack extends DeploymentStack {  
  constructor(scope: Construct, id: string, props: InfraProps) {  
    super(scope, id, props);  
  
    //Create Hosting Bucket  
    const docBucket = new Bucket(this, 'DocsBucket', {  
      versioned:true,  
    });  
  }  
}
```

Defaults:

- blockPublicAccess: BlockPublicAccess.BLOCK_ALL
- encryption: BucketEncryption.KMS
- enforceSSL: true
- publicReadAccess: false
- serverAccessLogsBucket: A logging bucket is created for you unless a bucket is specified.

<https://github.com/aws/aws-cdk/blob/main/packages/aws-cdk-lib/README.md#blueprint-property-injection>

Meet Your Developers Where They Are

AppSec should **not force** developers to change.

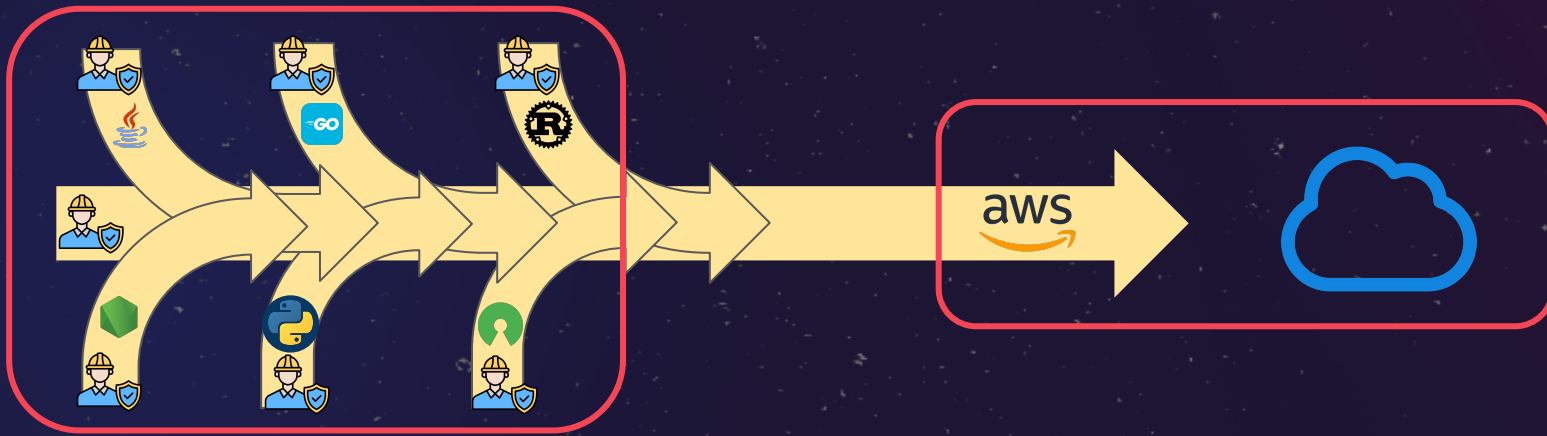


Can We Continue to Reduce Friction?



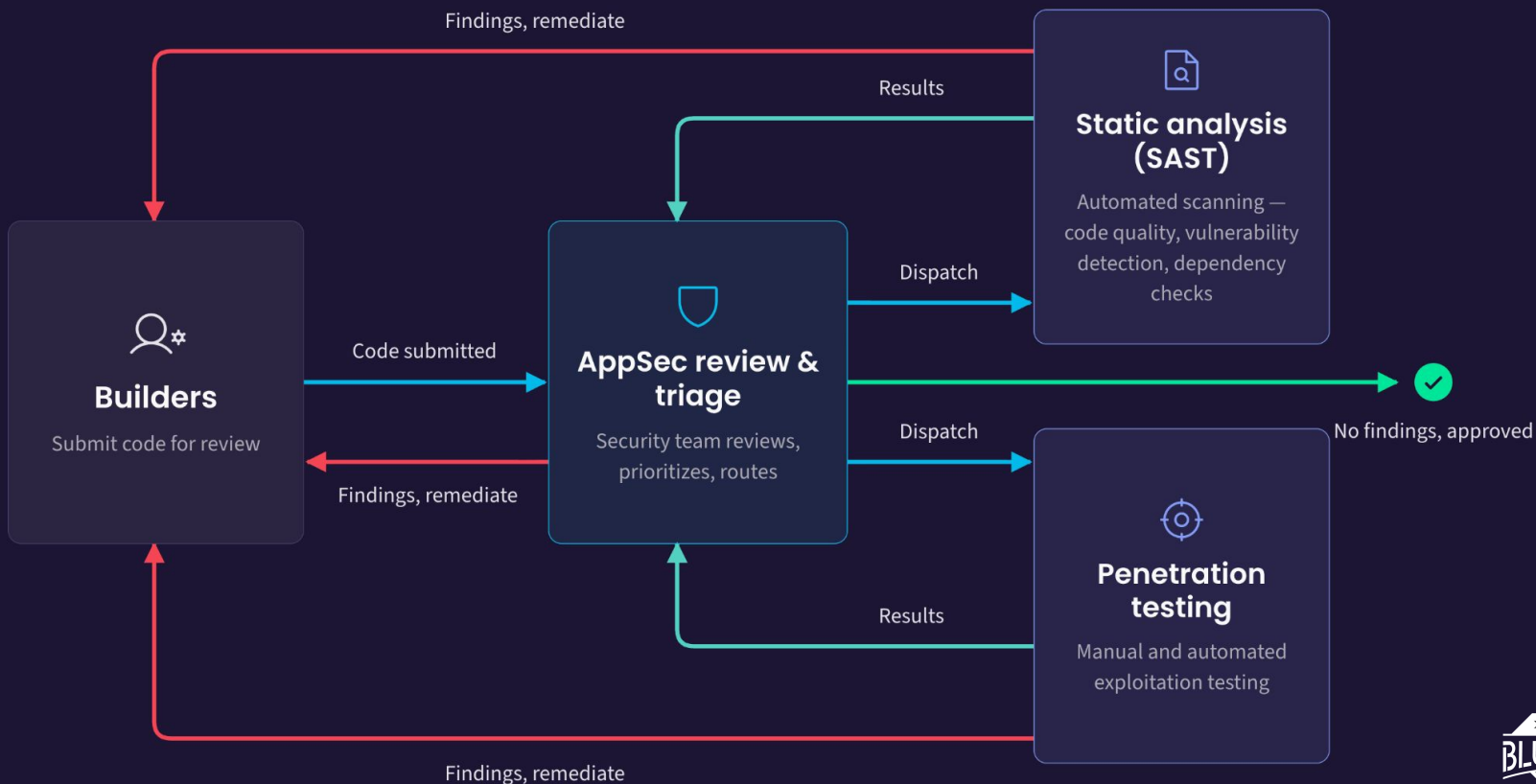
What if you could make
that block easier to push?

Secure-by-Default
Golden Paths



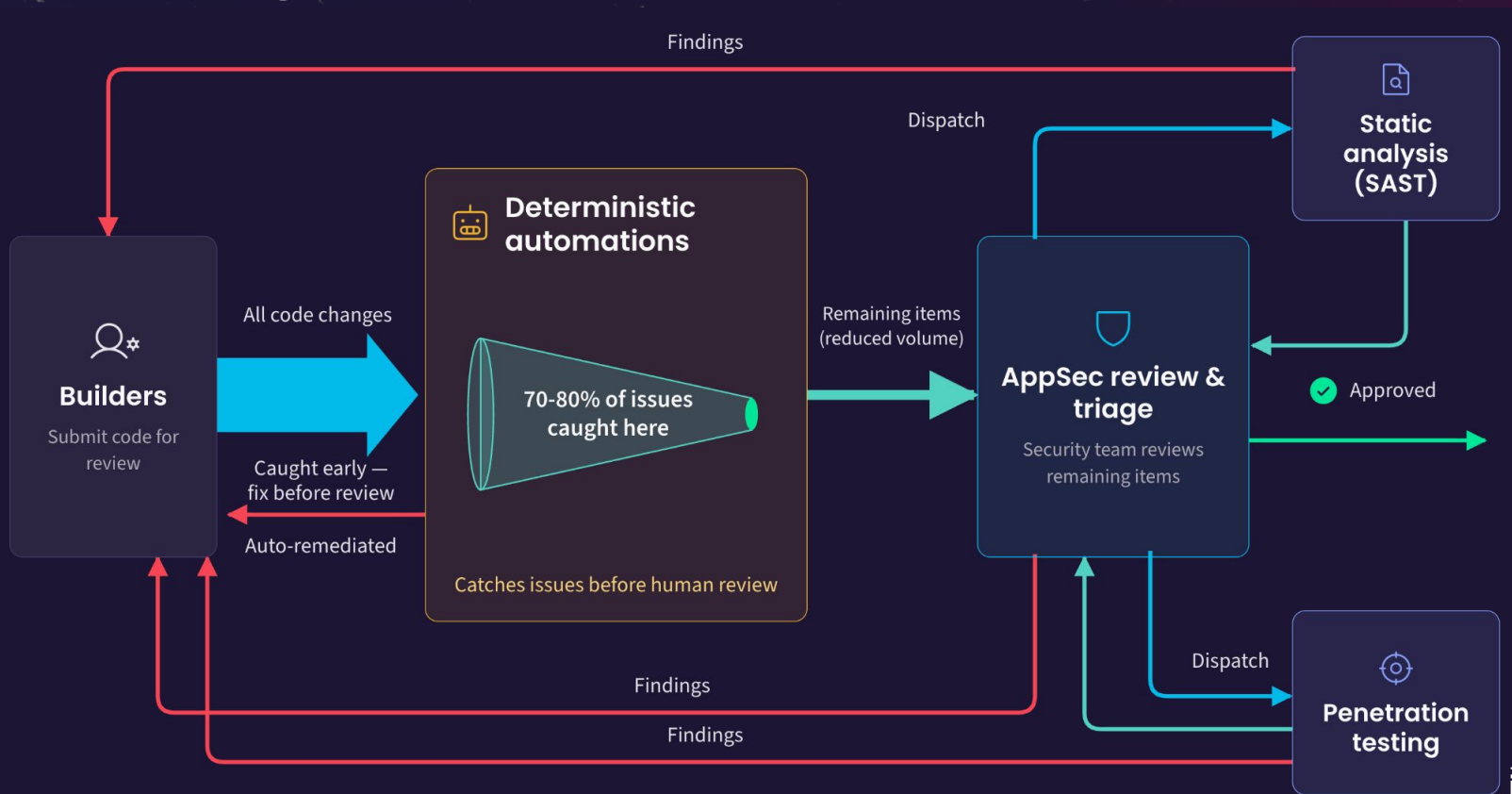


Traditional AWS AppSec Process





Adding Deterministic Automations





Building Automations in 3 Steps



1. Break Down Each Deterministic Task.

Manually triage every task.

2. Learn all the edge cases and document them.

Create a binary decision tree.

3. Test with manual automations, such as TamperMonkey scripts, CLI scripts, etc.

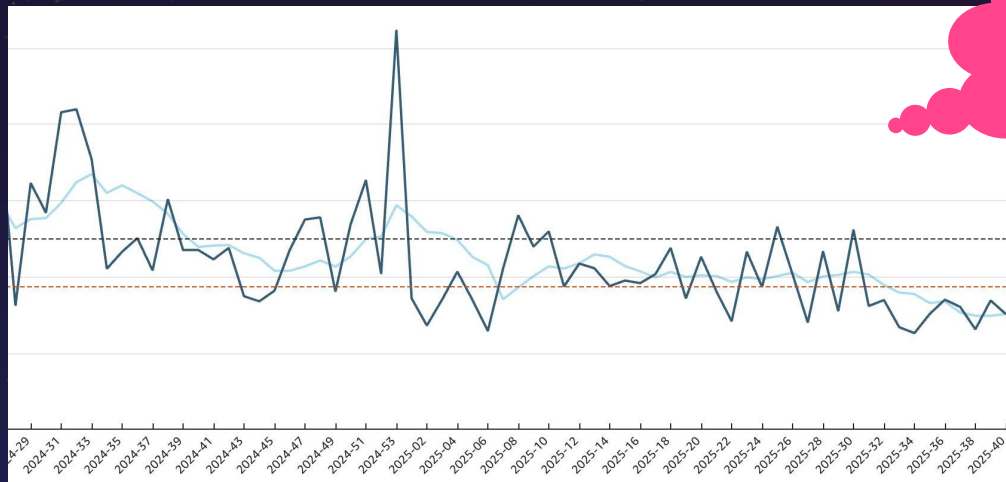
If you get consistent results, move to full auto.



Automation Wins

2024 time

2025 goal
25% reduction



Over a 30%
time savings!

2025 6wk
trailing avg

1,480 Pentester
Days Saved!



Adam Schaal • You

Distinguished Engineer, AI Security at Pixee AI

5mo •



Celebrating a team SHINE Win. 🌟

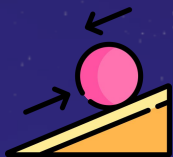
Some of the automations that my team have built over the last year have been so successful that we were able to actually remove portions of our Penetration Testing scope, which added up to 1,480 pentest days reduction per year! That's four extra headcount.

Deterministic Automations Are Worth Your Time

Spend time **writing automations** that reduce total work.



What else will break the AppSec mold?



What if you could make that block easier to push?

Secure-by-Default
Golden Paths



What if you could change the pitch of the hill?

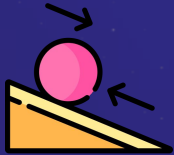
Automated Security
checks in the CI/CD.



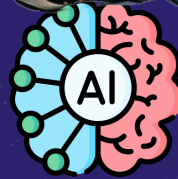
What if we don't have as much work?

Can we eliminate tasks and review types?

Let's take the day off.



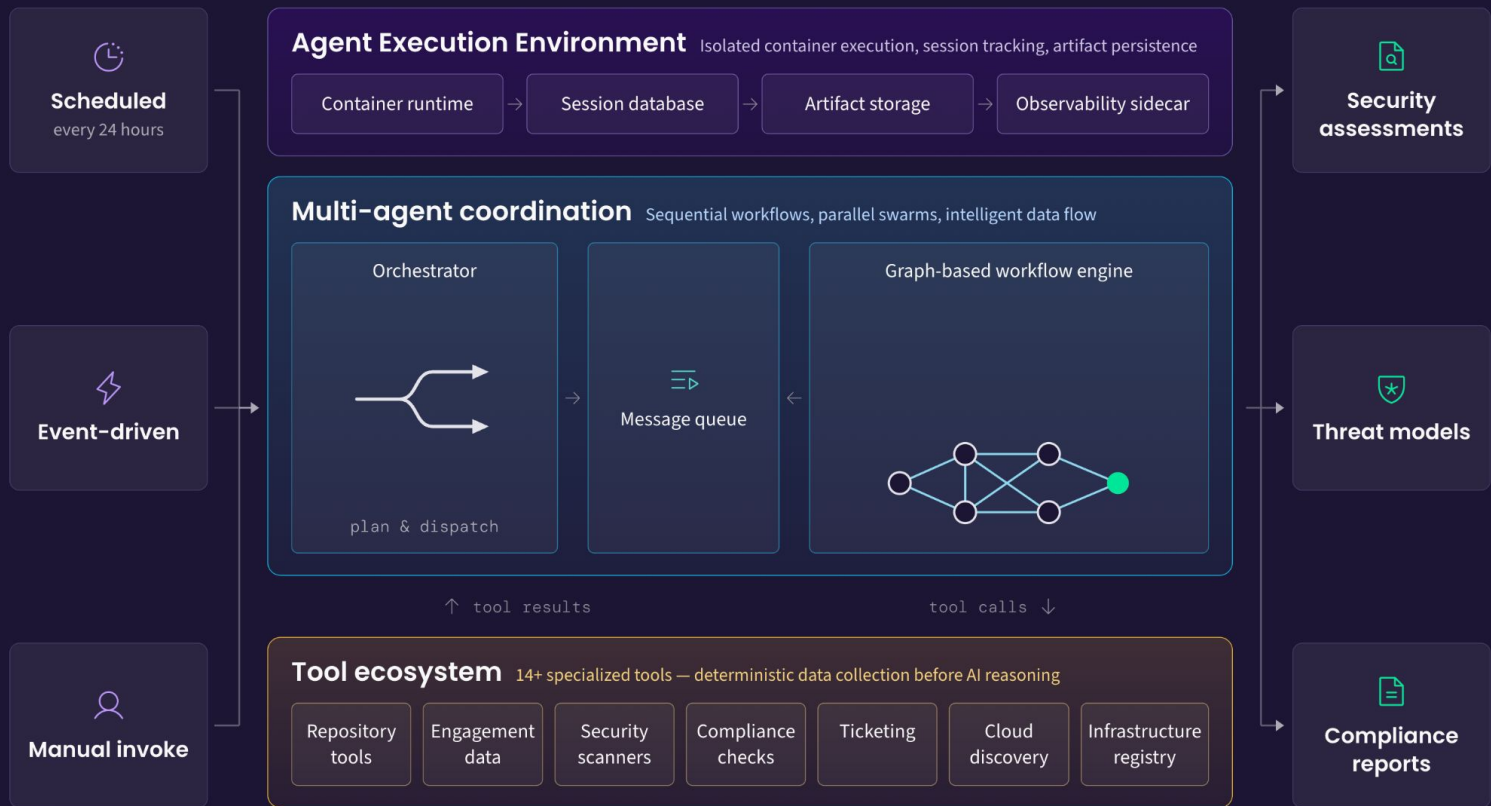
Can we make this roll downhill? Remove entire security review types?



Agentic GenAI
Solutions

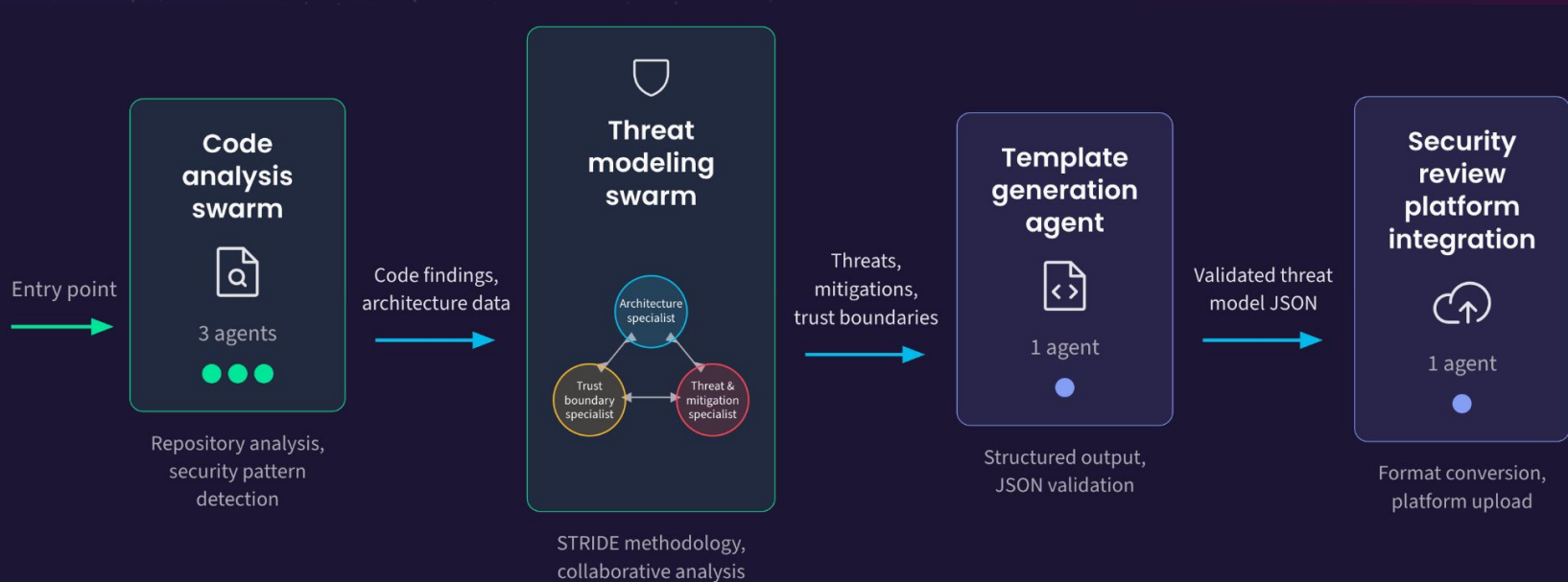


Building Non-Deterministic Automation





Threat Modeling Example



 Swarm (multi-agent collaboration)  Individual agent  Data propagation along edges



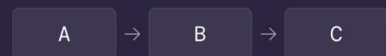
LLM as a CEO

Swarm coordination — collaborative agent teams

Specialists coordinate directly instead of waiting in a queue

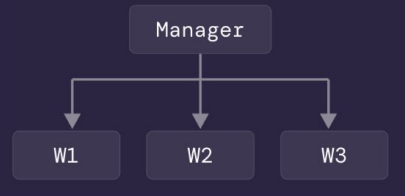
Traditional approaches

Sequential

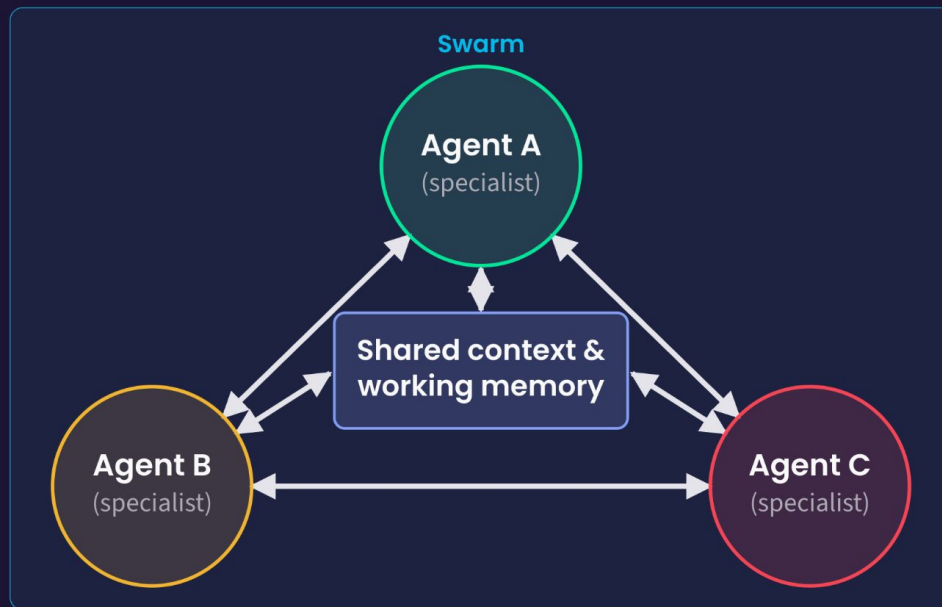


One at a time, no collaboration

Hierarchical



Top-down, bottleneck at manager



- ✓ Autonomous coordination
- ✓ Shared working memory
- ✓ Self-organizing teams

Adapts to the specific security challenge encountered



Human-in-the-Loop





Non-Deterministic Solutions



Each solution combines deterministic data collection (tools, scanners, APIs) with AI reasoning (pattern recognition, contextual analysis, expert judgment) — outputs adapt to the unique characteristics of each codebase and environment

Removing Security Reviews Matters Most

With **enough context**, you can create gen-ai tools that reduce total work.

Thank You.

Comments or Questions?



Would you like to connect?



@clevernyyyy



@appsec.bsky.social



/in/adamschaal



/clevernyyyy



clevernyyyy



blog.adamschaal.com